



Attacking Web Applications with Ffuf | Domain Fuzzing Write-up

HackTheBox

Written by: Alexander Sapo

DNS Records

Initial Setup

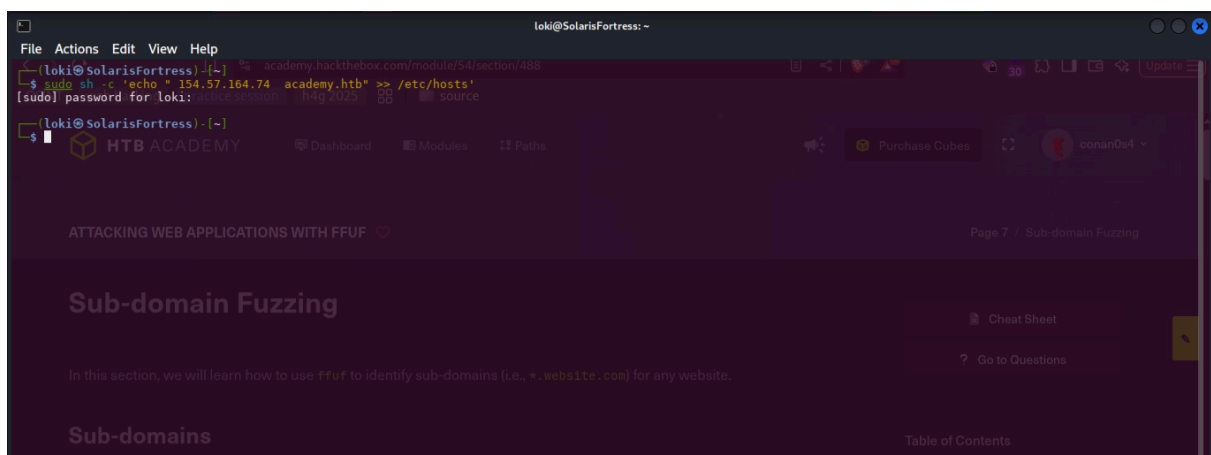
First: connect to academy.htb. We would have to add it to our `/etc/hosts` file because it is private/internal to be able to access it. Browsers can't resolve it via public DNS (like 8.8.8.8), so you must manually map it to the correct IP address in your local `/etc/hosts` file to access it.

We can achieve that with the following command:

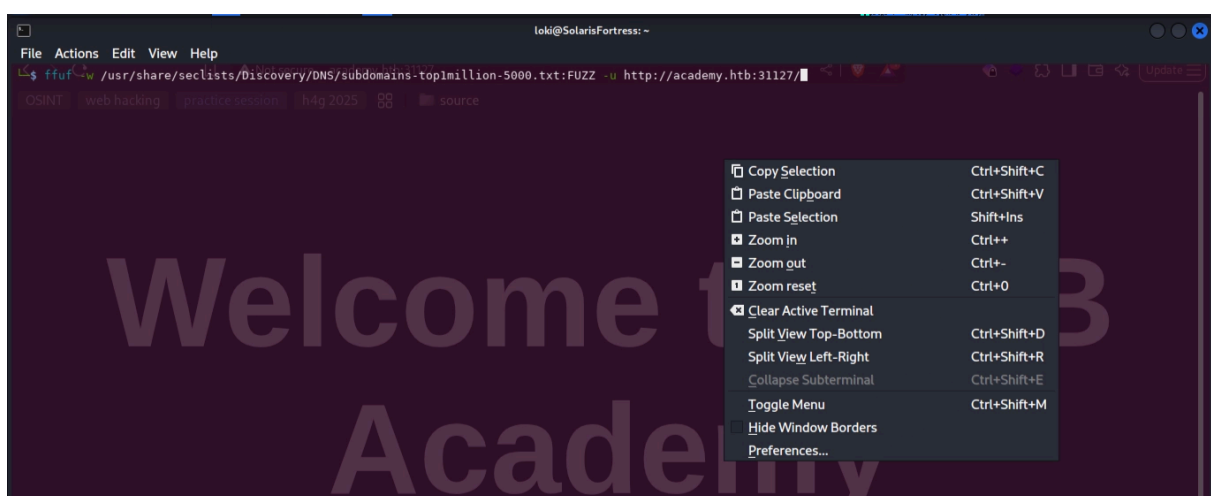
```
conan0s4@htb[/htb]$ sudo sh -c 'echo "SERVER_IP academy.htb" >> /etc/hosts'
```

Now we can visit the website (don't forget to add the PORT in the URL) and see that we can reach the website.

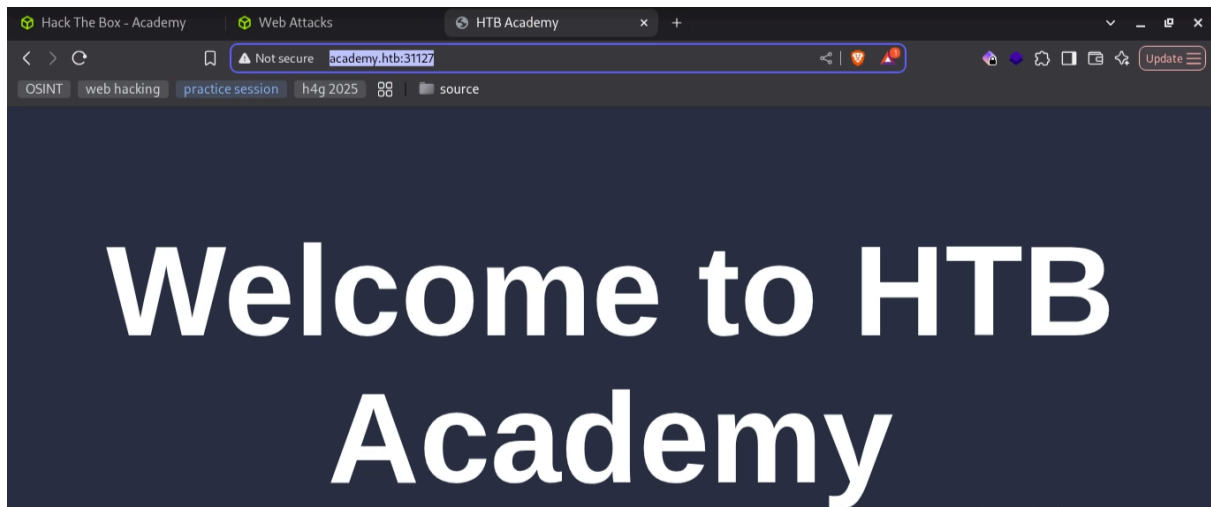
Now get the target that we have been using to practice on, which is in the Web Fuzzing module HTB (Attacking Web Applications with Ffuf).



```
command: sudo sh -c 'echo " 154.57.164.74 academy.htb" >> /etc/hosts'
```



Target:



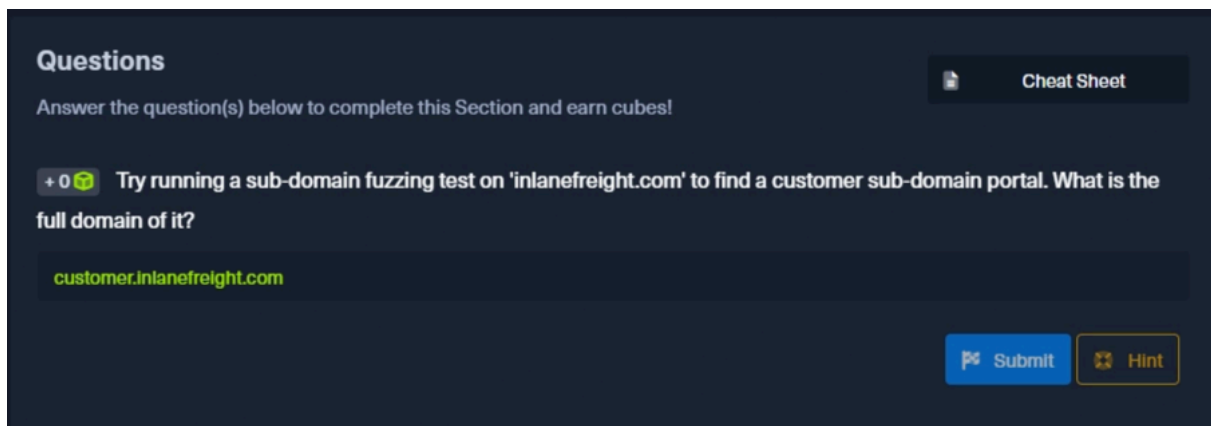
```
154.57.164.74:31127
```

Now we can access it:

```
http://academy.htb:31127
```

Sub-domain Fuzzing

Question



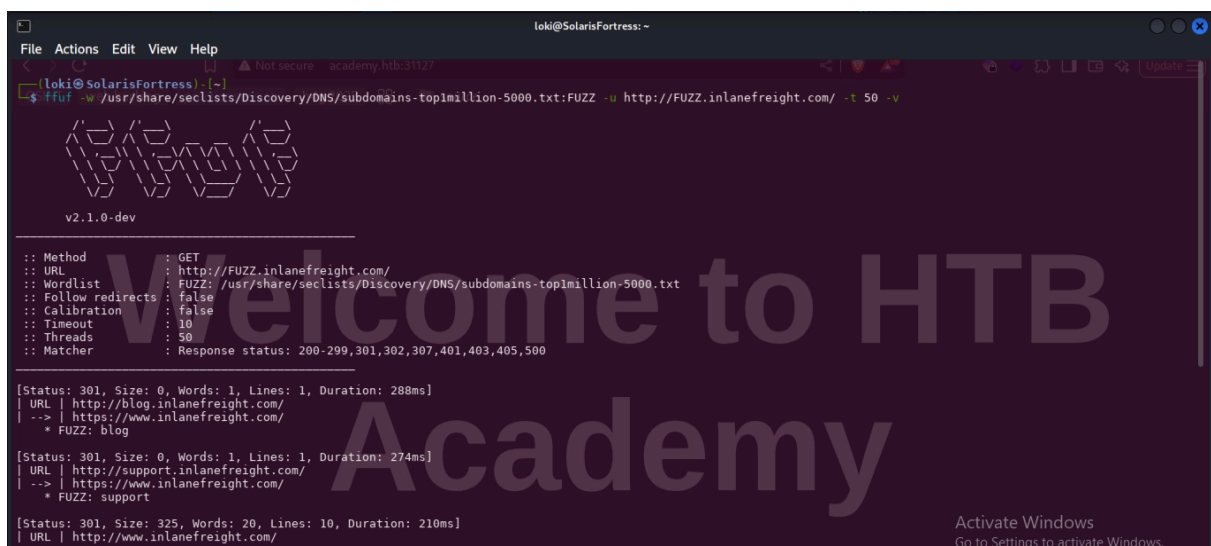
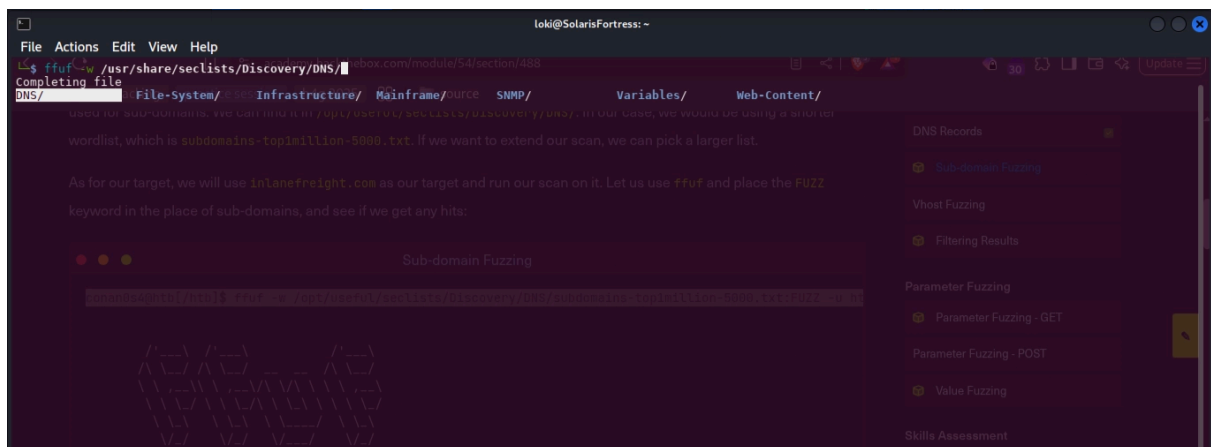
Try running a sub-domain fuzzing test on `inlanefreight.com` to find a customer sub-domain portal. What is the full domain of it?

Flag:

customer.inlanefreight.com

Process

First test — no hits:



```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u http://FUZZ.htb:31127/ -t 50
```

Why?

As mentioned:

We see that we do not get any hits back. Does this mean that there are no sub-domains under academy.htb? — No.

This means that there are no public sub-domains under academy.htb, as it does not have a public DNS record, as previously mentioned. Even though we did add academy.htb to our `/etc/hosts` file, we only added the main domain, so when ffuf is looking for other sub-domains, it will not find them in `/etc/hosts`, and will ask the public DNS, which obviously will not have them.

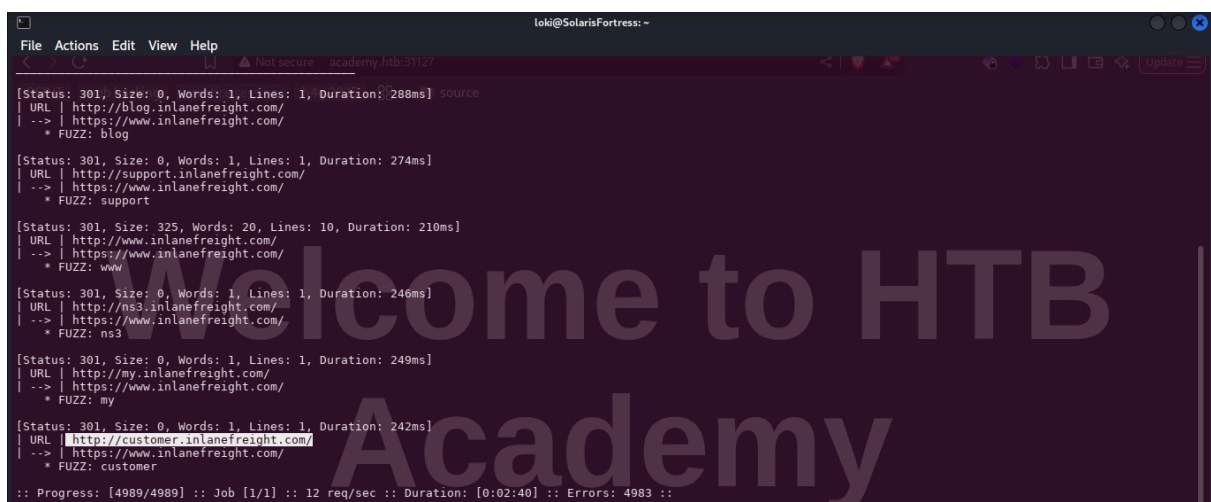
Only a demonstration.

Actual target: `inlanefreight.com`

Command example:

```
conan0s4@htb[/htb]$ ffuf -w /opt/useful/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u https://FUZZ.inlanefreight.com/
```

We found:



```
loki@SolarisFortress: ~  
File Actions Edit View Help  
[Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 288ms] source  
| URL | http://blog.inlanefreight.com/  
| --> | https://www.inlanefreight.com/  
* FUZZ: blog  
[Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 274ms]  
| URL | http://support.inlanefreight.com/  
| --> | https://www.inlanefreight.com/  
* FUZZ: support  
[Status: 301, Size: 325, Words: 20, Lines: 10, Duration: 210ms]  
| URL | http://www.inlanefreight.com/  
| --> | https://www.inlanefreight.com/  
* FUZZ: www  
[Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 246ms]  
| URL | http://ns3.inlanefreight.com/  
| --> | https://www.inlanefreight.com/  
* FUZZ: ns3  
[Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 249ms]  
| URL | http://my.inlanefreight.com/  
| --> | https://www.inlanefreight.com/  
* FUZZ: my  
[Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 242ms]  
| URL | http://customer.inlanefreight.com/  
| --> | https://www.inlanefreight.com/  
* FUZZ: customer  
:: Progress: [4989/4989] :: Job [1/1] :: 12 req/sec :: Duration: [0:02:40] :: Errors: 4983 ::
```

```
[Status: 301, Size: 0, Words: 1, Lines: 1, Duration: 242ms]  
| URL | http://customer.inlanefreight.com/  
| --> | https://www.inlanefreight.com/  
* FUZZ: customer
```

Vhost Fuzzing

As we saw in the previous section, we were able to fuzz public sub-domains using public DNS records. However, when it came to fuzzing sub-domains that

do not have a public DNS record or sub-domains under websites that are not public, we could not use the same method. In this section, we will learn how to do that with Vhost Fuzzing.

This is where we utilize VHosts fuzzing on an IP we already have. We will run a scan and test for scans on the same IP, and then we will be able to identify both public and non-public sub-domains and VHosts.

Command example:

```
conan0s4@htb[/htb]$ ffuf -w /opt/useful/seclists/Discovery/
DNS/subdomains-top1million-5000.txt:FUZZ -u http://academy.
htb:PORT/ -H 'Host: FUZZ.academy.htb'
```

Result:

```
mail2      [Status: 200, Size: 900, Words: 423, Lines: 56]
dns2       [Status: 200, Size: 900, Words: 423, Lines: 56]
ns3        [Status: 200, Size: 900, Words: 423, Lines: 56]
dns1       [Status: 200, Size: 900, Words: 423, Lines: 56]
lists      [Status: 200, Size: 900, Words: 423, Lines: 56]
webmail    [Status: 200, Size: 900, Words: 423, Lines: 56]
static     [Status: 200, Size: 900, Words: 423, Lines: 56]
web        [Status: 200, Size: 900, Words: 423, Lines: 56]
www1       [Status: 200, Size: 900, Words: 423, Lines: 56]
<...SNIP...>
```

In this case, we cannot use matching, as we don't know what the response size from other VHosts would be. We know the response size of the incorrect results, which, as seen from the test above, is 900, and we can filter it out with

```
-fs 900 .
```

```
conan0s4@htb[/htb]$ ffuf -w /opt/useful/seclists/Discovery/
DNS/subdomains-top1million-5000.txt:FUZZ -u http://academy.
htb:PORT/ -H 'Host: FUZZ.academy.htb' -fs 900
```

```
<...SNIP...>
admin      [Status: 200, Size: 0, Words: 1, Lines: 1]
```

When found — Note: Don't forget to add `admin.academy.htb` to `/etc/hosts`.

Try running a recursive scan on `admin.academy.htb` and see what pages you can identify.

Filtering Results

Question

Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): `154.57.164.64:32520` 🐞

Life Left: 74 minute(s)

+ 0 🐞 Try running a VHost fuzzing scan on 'academy.htb', and see what other VHosts you get. What other VHosts did you get?

`test.academy.htb`

[Submit](#) [Hint](#)

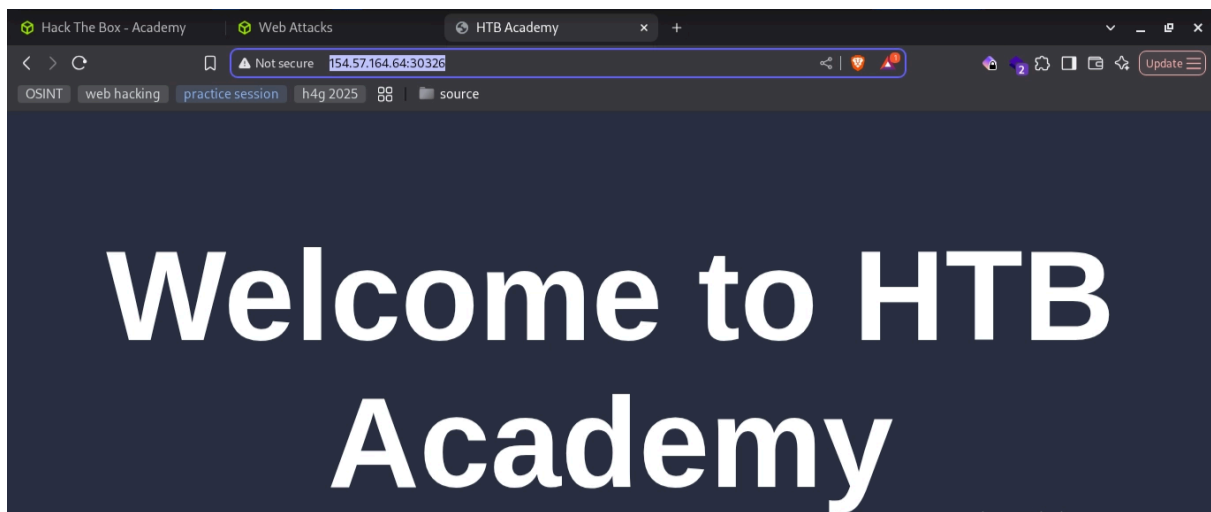
Try running a VHost fuzzing scan on `academy.htb`, and see what other VHosts you get. What other VHosts did you get?

Flag:

`test.academy.htb`

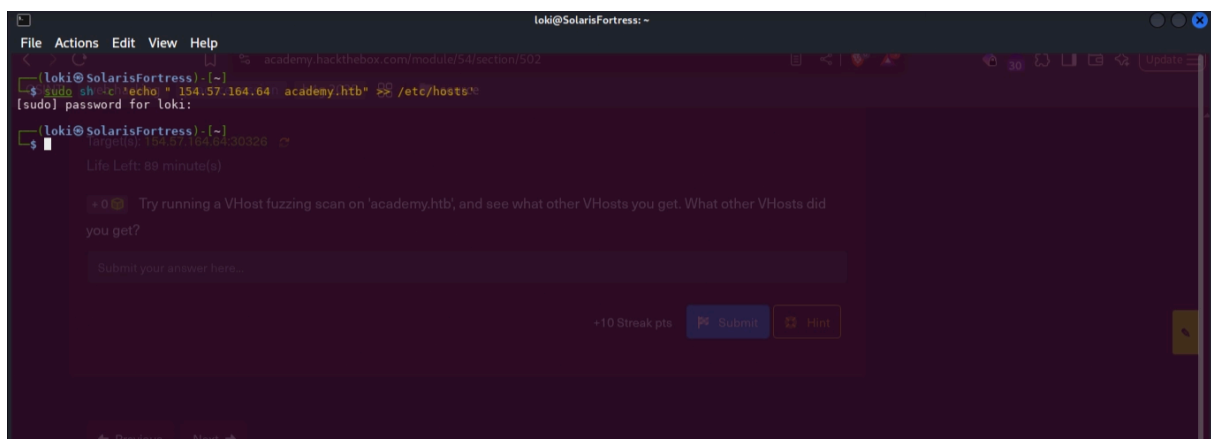
Process

First, get the target:



154.57.164.64:30326

Second, add it to `/etc/hosts` :



```
sudo sh -c 'echo " 154.57.164.64 academy.htb" >> /etc/hosts'
```

Third step is fuzzing with filter `-fs 900` , and also specify the port:

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u http://academy.htb:30326/ -t 50 -H 'Host: FUZZ.academy.htb'
```

Common size: 986


```
loki@SolarisFortress: ~  
File Actions Edit View Help  
academy.hackthebox.com/module/54/section/502  
[loki@SolarisFortress] [-]  
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u http://academy.htb:30326/ -H 'Host: FUZZ.academy.htb'  
  
v2.1.0-dev Try running a VHost fuzzing scan on 'academy.htb', and see what other VHosts you get. What other VHosts did you get?  
:: Method : GET  
:: URL : http://academy.htb:30326/  
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt  
:: Header : Host: FUZZ.academy.htb  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
+10 Streak pts Submit Hint  
  
old [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 206ms]  
beta [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 207ms]  
pop [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 208ms]  
ns4 [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 208ms]  
new [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 208ms]  
ns1 [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 208ms]  
cpanel [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 209ms]  
ns [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 208ms]  
test [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 207ms]  
blog [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 208ms]  
ns2 [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 209ms]  
Activate Windows  
Go to Settings to activate Windows.
```

Let's use this as the filter.

```
ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u http://academy.htb:30326/ -t 50 -H 'Host: FUZZ.academy.htb' -fs 986
```

Result:

```
loki@SolarisFortress: ~  
File Actions Edit View Help  
academy.hackthebox.com/module/54/section/502  
[loki@SolarisFortress] [-]  
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt:FUZZ -u http://academy.htb:30326/ -H 'Host: FUZZ.academy.htb' -fs 986  
  
v2.1.0-dev Try running a VHost fuzzing scan on 'academy.htb', and see what other VHosts you get. What other VHosts did you get?  
:: Method : GET  
:: URL : http://academy.htb:30326/  
:: Wordlist : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt  
:: Header : Host: FUZZ.academy.htb  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200-299,301,302,307,401,403,405,500  
:: Filter : Response size: 986  
+10 Streak pts Submit Hint  
  
test [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4896ms]  
admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4896ms]  
:: Progress: [4989/4989] :: Job [1/1] :: 177 req/sec :: Duration: [0:00:30] :: Errors: 0 ::  
[loki@SolarisFortress] [-]  
$
```

```
test [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4896ms]  
admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4896ms]
```